The Financial Impact of Malware

STUDY PROJECT 1

JOHN LIEN

JSL

Course code	FS1SP1131
Course title	Study project 1
Assignment title	The Financial Impact of Malware
Date	1/18/2022

Contents

Acronym Handbook 2
Introduction 3
Basic Introduction of Malware 4
Norton's Top Ten types of Malware 5
Criminal use of malware 8
Successful attacks 8
Malware as a service 10
Ransomware as a service 11
Ransomware 12
Costs of a malware attack 15
Government involvement 17
Incident response plan 18
You have been hacked 19
Conclusion 23
References 24
Additional references 30

JSL

Acronym Handbook

Acronym	Explanation	Acronym	Explanation
RaaS	Ransomware-as-a-service. Ransomware being sold by hackers	MaaS	Malware-as-a-service. Malware being sold by hackers
DDoS	Distributed-Denial-of-Service. A cyberattack that could bring your service offline for hours.	RAT	Remote Access Trojan
Zero-day vulnerability	A vulnerability known for zero-days, until someone utilizes the vulnerability.		
FBI	Federal Bureau of Investigations. A US government organization	CISA	Cybersecurity & Infrastructure Security Agency. A US government organization
NSA	National Security Agency. A US government Organization	PST	Norwegian Police Security Service (Politiets Sikkerherhetstjeneste). A Norwegian government organization
FSB	Federal Security Service (Federal'naya sluzhba bezopasnosti Rossiyskoy Federatsii). A Russian government organization	GRU	Main Intelligence Directorate of the General Staff of the Armed Forces of the Russian Federation (Glavnoye Razvedyvatel'noye Upravleniye). A Russian government organization
APT38	Ties to the North-Korean government. Connected to Lazarous Group	APT27	Ties to the Chinese government. Connected to Emissary Panda and Winnti groups.
APT28/29	Ties to the Russian government. Connected to Fancy Bear, STROTNUM and UNIT 26165	PII	Personally Identifiable Information
IDPS	Intrusion Detection and Prevention Systems	NGIPS	Next-Generation Intrusion Prevention System
MSP	Managed Service Provider		

JSL

Introduction

This report will cover multiple aspects of malware, but it will mainly be focused on the financial aspect for your business. Malware is a very big issue and can never be protected against 100% of the time. However, we can mitigate this issue and keep the chances of it happening low. We can also recover quicker from an attack if we are ready for it and has a plan ready for execution. If big organizations like Norsk Hydro, Acer, Colonial Pipeline Company, AXA S.A and Ireland's Health Service Executive was successfully hit and taken down, then so can you and every day that passes, the threat could be right around the corner. Criminal organizations like Twisted Spider, Viking Spider, Wizard Spider, APT28, Lockbit Gang and Sodinokib (REvil) are looking to earn money, and you could be their next target. Different organization run by the United States of America has gone out and warned that ransomware attacks are on the rise, and are a rising threat.

We are going to explain what malware is, why you should be concerned and ready for a potential attack, Ransomware-as-a-service, how malware is spread, cybercriminal market, malware on the global scale, financial gain/loss by an attack, business cost, consumer costs, business competition using cybercriminals and why you should have a response plan if you get hit by malware.

Please keep in mind: We assume that the reader has basic computer knowledge, basic knowledge about acronyms concerning cyberattacks, and that the business has a previously established IT operation.

We do not recommend visiting the dark net malware sites. They can carry viruses themselves or you can accidently get your private information and browser hijacked. Click links in this article on your own accord, we do not have any responsibility if these links lead to potentially dangerous sites. They shouldn't be dangerous, but webpages can change without us knowing about it.

Basic Introduction of Malware

First off, malware isnt just a single thing. It is a collection of various types with different capabilities. According to Norton, these are the ten most common types of malwares (Stouffer, 2021):

- Virus
- Worm
- Trojan
- Ransomware
- Bots / Botnets
- Adware
- Spyware
- Rootkits
- Fileless Malware
- Malvertising

These might not seem dangerous for your business, but they can impact your business. Advanced types might even bring your business completely offline or force you to shut down for good. There is a huge market for cybercriminals where they sell both malware software and data from malware attacks. Data could be personal information about your customers, username and passwords, business secrets, upcoming investment plans, source code for your business's specialized software and much more. These attacks are not just carried out by cybercriminals. They could be carried out by a disgruntled employee, competition, criminals, or an unhappy customer. These attacks can be bought and sold for anything in between a couple USD up to many thousands USD. It is a problem that business competition hires hackers and launches damaging cyberattacks. Industrial sabotage is a problem and could just as well be happening to your business tomorrow or right now without your business knowing it. Competition, criminals, or foreign governments could gain valuable insight into your business and receive full remote control over your systems or customers systems. According to Kaspersky (Businesses Blame Rivals for Staging DDoS Attacks, 2017), in Western Europe, 37% of businesses hit by a Distributed-Denial-of-Service (DDoS) attacks blame the competition and 17% of businesses blame foreign governments. What makes DDoS attacks dangerous, is that they can be used to hide an ongoing cyberattack where the businesses data could be stolen. This can happen right under your nose. "It is clear that businesses feel their IT systems and private data are under siege from all sides," says Kirill Ilganaev, head of Kaspersky DDoS protection at Kaspersky Lab. "With DDoS attacks becoming so frequent and so crippling, many suspect their competitors are behind them, as they look for ways to put their rivals out of action and steal their customers as a result (Evans, 2017)."

Norton's Top Ten types of Malware

- Malware viruses – Usually put into software and needs to be executed by the user.
  Example: Opening email attachments from untrusted sources. This attachment could look like a normal word document but could also include malicious code that you cannot see with the human eye. The user downloaded this document, opened it, and executed the virus without knowing it. This attack could go unnoticed without a system actively scanning for it.
- Worm Malware – Very similar to viruses mentioned above. This type does not need to be executed by the user and can replicate itself without user interaction. This attack could go unnoticed without a system actively scanning for it.
  Example: One of your employees brings in a private USB drive and plugs it into his business pc. Once he interacts with this usb drive the worm starts to replicate itself. Advanced worms can detect online storage spaces where they replicate and spread through the entire business if they aren't dealt with.
- Trojan Malware – Malware distinguished as another piece of software. It functions just as the Trojan horse we know of in history. It disguises itself as real and legit software, but its true nature is hidden behind a "legitimate" layer.
  Example: A supervisor with administrative access downloads what he thinks is the Google Chrome Web Browser from a usb drive someone gave him. The Supervisor is happy and thinks nothing else of it. What he doesn't know is that the software given to him is not the real installation software, its modified by a cybercriminal to act as a Web browser but also inject the supervisor's computer with malware.
- Ransomware – Encrypts data drives, makes a business's system unusable and holds the encrypted data ransom. The cybercriminals behind this usually demand payment in cryptocurrency within a certain timeframe. Ransomware can spread over networks or just inhabit the computer it first got downloaded on. These attacks could be random or targeted.
  Example: A supervisor gets an email from an untrusted source outside the company. Supervisor sees there is an attachment to the email, supervisor downloads it and runs it thinking it is a harmless file. The file does not open and closes when the supervisor try to open it. The supervisor's computer immediately locks and shows "YOUR SYSTEM IS NOW HELD FOR RANSOM AND ENCRYPTED. PAY NOW TO GET CODE TO DECRYPT SYSTEM – 3 BITCOINS SENT TO ADDRESS: bc1qar0srrrxxfkvy5l6xxxxxxw9re59gtzzwf5mdq. YOU HAVE 2 DAYS"
  Similar screens are showing up at every co-workers desk and the business is unable to perform the service it sells to its customers.
- Bots/Botnets – A bot is a hijacked computer being controlled and is called Bot, short for Robot. A Botnet is the collection of hijacked computer bots. Attacks are carried out by many thousands of bots collected into a botnet. These bots can take full control over your systems or abuse the systems connection to the internet for DDoS attacks. This attack could go unnoticed without a system actively scanning for it.
  Example: Malicious code gets uploaded to a server by a disgruntled employee. This employee might know what the code does or just found it online. The server could now be a hijacked by a cybercriminal and used for illegal activities. Your server could run slower, record every file on the server and send it to the cybercriminal, and could be used for illegal DDoS attacks where you get the blame.

- Adware – The main purpose is to serve the user annoying advertisements and deliver the user to malicious sites where other types of malwares can be downloaded and installed. It can come with web browser addons that are malicious or previously downloaded software on the supervisor's system. This attack could go unnoticed without a system actively scanning for it.
  Example: Supervisor has previously installed software that automatically installed and hid a web browser addon. This addon modifies the ads being delivered to the user and servers malicious web sites instead of legit web sites. Supervisor clicks on advertisements and proceeds to download what looks like legit copies of software supervisor was looking for. Now the supervisor has potentially downloaded a trojan malware and set the whole company in potential danger for a cyberattack.
- Spyware – Malware that spies on the user's system, or multiple systems and sends data back to the cybercriminal. This potentially gives cybercriminals, foreign governments, and competitors valuable insight and control of the future for your company. Keystrokes and data could be sent to cybercriminals without your knowledge. This attack could go unnoticed without a system actively scanning for it.
  Example: The supervisor has installed software from an advertisement online. Supervisor logs into one of the servers containing confidential data from a customer and starts working. On supervisor's computer there is a keylogger that records and sends everything he types to the cybercriminal. The cybercriminal can use the data being recorded to log into the server containing confidential customer data and access it with supervisor's access level. If the server is set up wrong or lacks security, the cybercriminal could have administrative or root access to the server. All the data can be accessed, modified, downloaded, or deleted. This could be blamed on the supervisor or traced to an outside source. The damage potential is huge.
- Rootkits – This type of malware is designed to be hidden and grants remote access of the victim's computer to the cybercriminal. Cybercriminal can now access the victim's computer and gather as much data as it wants. If the user has administrative access the cybercriminal can access and potentially change the businesses internal network structure, compromise security, launch a ransomware attack or potentially destroy a business. If this attack does not get noticed and dealt with, it could potentially bring down servers every time the company's IT personnel reboots it. This attack could go unnoticed without a system actively scanning for it.
  Example: A supervisor with administrative access has downloaded software from a malicious ad it was served months ago. A business competition has hired a cybercriminal to remotely turn off servers and download confidential data during the businesses most busy week. This can potentially turn customers away from the business and could destroys its reputation among customers.
- Fileless Malware – This type of malware only needs to be executed once and after the first execution it installs itself into different types of real and safe software. It abuses security flaws in these types of safe software and run malicious code behind safe software. It could abuse Word, OneNote, Outlook, Chrome Web Browser, Firefox Web Browser, or the software you use to open PDF documents. This attack could go unnoticed without a system actively scanning for it.
  Example: Supervisor inserts a usb drive he got from a colleague, without supervisors' knowledge this employee is being paid by a cybercriminal to spread malware. The usb drive contains only a picture that supervisor opens and then returns the usb drive. The fileless malware is now

spreading throughout its computer. Supervisor opens Word and Outlook to work on some confidential files. The fileless malware can now use these software programs to piggyback on them and keep spreading itself to other types of open software including disrupting supervisor's antivirus service.

- Malvertising – Not Adware. It comes from legitimate websites and is being placed on the website by a malicious actor. Sometimes the business serving these advertisements does not check the code well enough and lets malicious ads infiltrate legitimate websites. This makes it easier to appear as a legit ad and get clicked on by website users. This spreads malware and can often be an attempt to steal users creditcard data by serving the user a safe looking website that requires the input of credit card information. This attack could go unnoticed without a system actively scanning for it and if the users are not trained to spot these potential malicious ads.
  Example: A user is visiting a real website to a news firm. They serve advertisements on the side of their website and is using a third party to deliver these ads. The third party does not check any of their advertisements and deliver anything they get paid to deliver. The user sees an advertisement for a vacuum the business needs and is redirected to a cybercriminals seemingly safe website. The user is requested to pay and inputs the company's credit card details. The credit card is charged 10000 USD. This is money that is potentially lost, and the company must waste time reporting credit card fraud. The credit card issues might not refund the amount that was stolen, and this makes the business lose money.
  (Stouffer, 2021)

JSL

Criminal use of malware

Cybercriminals are everywhere and could be your neighbor. The internet contains many sites where they offer Malware-as-a-Service (MaaS) and even provide technical support for their service. MaaS is malware readily available for customers to pay and gain private access to. It could be botnets for distributing types of malware or rootkits the cybercriminal puts into the victim's system for the paying user to gain control of. These organizations provide everything from small hacks planting keyloggers to ransomware attacks that bring down businesses worth billions of dollars.

The internet is so widespread that criminals have long since moved into it and adapted. Criminal organizations can hire or be started by people with computer knowledge but to be the best at serving malware, they must have knowledge beyond what the regular human can provide. These humans can even be experts that see how much money can be gained from criminal actions. Ransomware has made news headlines the past couple years and is being carried out by efficient criminal groups. Some of the bigger criminal organizations have carried out attacks against multiple victims at once successfully. Ransomware has quickly become an issue for everyone on the internet. Small time users, small businesses, big businesses, and governments can be targeted. The most well-known groups have targeted everything from health services to government organizations, and even bringing their service to a complete stop. They could just as well target you or your business.

Ransomware gets executed by a user and this proceeds to encrypt everything while displaying a note to the user with information from the hackers. Sophisticated ransomware attacks can encrypt data, notice network drives, and encrypt them, spread itself using network drives, send potentially internal sensitive documents to the hackers, and completely bring a business offline or abuse the system to do irreversible damage. Without backups and a ransomware response plan, you could be forced to shut down temporary or permanently. The hackers use sensitive internal files as incentive to get the targeted company to pay the ransom, or they release the files to the public. These files could be customer information, information on CEO's or higher standing employees, future for the company or company secrets. No-one is safe from these attacks. They have proven to be both financially and politically motivated. Some also believe the criminal organizations are sponsored by foreign governments to disrupt service and steal sensitive documents.

Successful attacks

These are some of the businesses that have been targeted, which criminal group organized it and potential payment of ransom:

- USA's The Colonial Pipeline Company was targeted with Ransomware by the group Darkside and had to shut down everything to stop the spread of ransomware. It cost them 4.4 million USD just to get access and sensitive files back from the hackers. This attack caused gas shortages in the USA on the East Coast (Colonial Pipeline Cyber Incident, 2021) (Colonial Pipeline boss confirms $4.4m ransom payment, 2021).
- Kaseya was targeted with Ransomware by group REvil and has not said publicly if they paid the ransom or initiated a response plan. The ransom was put at 45000 USD (Symantec, 2021).
- Acer has been targeted twice by REvil, first ransom set at 30 million USD, the second one at 50 million USD but quickly increased to 100 million USD. REvil quickly leaked sensitive documents in this hack and these documents are publicly accessible (Mathews, 2021).

- CNA Financial was successfully hit by Phoenix which used “Phoenix” (Hades ransomware spinoff) ransomware program to attack the company. This attack had a ransom set to 60 million USD and CNA paid 40 million USD to get access back (Mehrotra and Turton, 2021).
- ExaGrid was hit by Conti. The ransom was set at 7,5 million USD but only 2,6 million USD ended up being paid. Conti held multiple SQL servers, file servers and over 800GB’s of data as ransom. (Nichols, 2021) (Rieß-Marchive and Adshead, 2021)
- AXA S.A was hit by the group called Avaddon. They held over 3TB’s of data ransom, sensitive medical forms from customers and employees, contracts, payments, id’s, reimbursements and more as ransom. (Insurance giant AXA victim of ransomware attack, 2021)
- Ireland’s Health Service Executive was hit by Conti ransomware and the Irish Government refused to pay ransom. (PWC, 2021) (Umawing, 2021) (Gallagher, 2021) (Halpin and Humphries, 2021).
- Norwegian Media company Amedia’s operations were disrupted by malware and has had their data encrypted. They have also been threatened by the hackers. (Buggeland, 2021) (Oppdatering om dataangrepet mot Amedia, 2022) (Sviggum, Berge Christensen and Heiberg Hellstrand, 2021)

There are also many different groups that create ransomware, and some of them have made a lot of money over the years. The fact that these big companies and government organizations was successfully infiltrated and attacked shows the need for security experts and response plans. According to Unit42 (Highlights from the 2021 Unit 42 Ransomware Threat Report, 2021), the criminal organizations demand an alarmingly increasing amount of money for decryption tools that has the keys to decrypt the data they hold for ransom. On average, ransom being paid by companies rose from 115’000 USD in 2019 to 312’000 USD in 2020. Between the same years, the highest ransom ever paid was recorded being 5 million USD in 2019 and 10 million USD in 2020. In comparison, the two highest demands were for 15 million USD in 2019 and 30 million USD in 2020. To put it short, this is a lot of money for organizations that already have a set budget to work out from.

There is obviously a market for government and private organizations to make a lot of money of ransomware. Ransomware as a service has also quickly become a thing. One ransomware group called Spider Wizard has created ransomware called Conti, Ryuk, Diavol. They trade licenses to their software for a share in the profits from attacks (Hanel, 2019). These groups go under many different names and can be financed by anyone with ill intent against a company.

Malware as a service

Kaspersky defines Malware as a service (MaaS) as "The lease of software and hardware for carrying out cyber-attacks. Owners of *MaaS* servers provide paid access to a botnet that distributes malware. Typically, clients of such services are offered a personal account through which to control the attack, as well as technical support (Malware-as-a-service (MaaS), n.d.)." If someone has malicious intents towards your company, they can buy malware for as low as 50 USD on a dark web marketplace and deal massive damage to your business's infrastructure. These marketplaces are accessible on the open internet or by accessing a .onion website. .onion websites are accessible only by using TOR and its anonymous. Here you can easily browse multiple different vendors and types of malwares that range in price, from $50 USD to $10000 USD. You can also access private forums and buy from there for a higher price. Memberships to these private forums range between $200 USD to $600, but they can also contain very sophisticated software made by premium sellers. Vendors offer standard malware that is aimed at everything, and they offer customized hacks aimed at corporations (Mikalauskas, 2020) (Greig, 2020).

The services these hackers provide vary in efficiency, but many of these verified hacks work and they are cheap. A RAT with support can go for as little as $800 USD. With this tool, the attacker can remotely access the infected computer in real time. As previously mentioned, these hackers offer malware modules on their bots. The modules can be keyloggers, hijacking clipboards, bots (make you a part of a botnet), worms, virus, ransomware, and anything that qualifies as malware. The price for all these modules can be as low as $2500 USD. Customized ransomware for attacking corporations can be acquired for $800 USD and up, it depends on the abilities of the ransomware and quality. Some hackers are also selling complete packages for anyone to attack businesses and halt production of wares. These hackers go more in depth and usually don't have a set price. Some of the malware mentioned above use a subscription model, payment each month, with software updates and support. Some vendors maintain manuals and provide you with videos on how to use their software. (Mikalauskas, 2020) (Greig, 2020).

Completely free software also exists but vary in quality, efficiency and might not work the way its intended or not do the damage the attacker wants it to do. You can easily search around on YouTube for instructional videos on how malware works and how to make it. A user with basic computer skills can do it, but they might not make sophisticated malware like some of the famous marketplace vendors do.

Ransomware as a service

Trend Micro defines it as “Ransomware as a service (RaaS) is a business model that involves selling or renting ransomware to buyers, called affiliates. RaaS can be credited as one of the primary reasons for the rapid proliferation of ransomware attacks, as it has made it easier for a variety of threat actors — even those who have little technical knowledge — to deploy ransomware against targets (Ransomware as a Service (RaaS), n.d.). “

Darknet marketplace vendors sell everything from drugs, assassinations, malware and more specifically: ransomware. The ransomware these marketplaces sell could be completely customized for a specific corporation, or it could be licensed ransomware software from a renowned group. It can be found on the normal marketplaces where you can get MaaS, private forums, direct referral to sellers or through Telegram/Signal messages app. Private forums usually require referral from other verified members and/or a “VIP” fee that can range between $200 USD to $600 USD (Kickass Private Forum,). This “VIP” fee is only for gaining access to the forum and not for any types of software. The private forums usually contain very sophisticated ransomware and ways of contacting known groups that carry out attacks. These vendors can provide you with one-time licenses to ransomware or ransomware based on subscription models. Sometimes they will provide manuals, videos, and technical support for their product, but this might also be accessible for an additional fee paid by the user. Ransomware packages might be completely customized for a corporation and include software to decrypt the attacked system, but this is always confirmed by the seller in the advertisements. For the end user, these attacks are easy to carry out and require barely basic knowledge of how computers work. If someone would want to hit your business with ransomware it could be as easy as sending a malicious attachment in an email to your support email. Support personnel might open the attachment thinking its harmless but in reality it is ransomware. Without any knowledge, your support personnel might have run a .exe file that hijacks your servers, computer systems and starts to scan files for information that the hacker wants. It is pretty “easy” to avoid all this. We will write about how to avoid it further down (Kickass Private Forum, Zero Day Forum/Marketplace, 0x00sec Forum/Marketplace, CryptBB Forum/Marketplace) (Mikalauskas, 2020) (Greig, 2020) (Swinhoe, 2020).

Spider Wizard’s Conti is a great example of dangerous and sophisticated ransomware that use the Ransomware as a Service Model. Conti has grossed over 16.2 million USD since the ransomware was identified in early 2020 (Cable, n.d.).

Ransomware

Trend Micro defines ransomware as "… a type of malware that prevents or limits users from accessing their system, either by locking the system's screen or by locking the users' files until a ransom is paid. More modern ransomware families, collectively categorized as cryptoransomware, encrypt certain file types on infected systems and force users to pay the ransom through certain online payment methods to get a decryption key (Ransomware, n.d.)."

Ransomware is the hardest hitting one against a stable business economy. It creates costs from start to end. These attacks usually work like this:
Ransomware encrypts everything it gets access to, locks users out of the attacked computer system, gives remote access to the attackers and provides the victim with a way of communicating with the attackers while displaying the ransom they are required by the hackers to pay. This gives the attackers access to the encrypted data which they transfer to themselves. The encrypted data is held for ransom (Module 2 - Vulnerabilities, Malware & Cryptography -> Lesson 2.4 Crypto-Malware, n.d.).

Groups carrying out these attacks encrypt everything they can see on the victims computer and transfers sensitive documents to themselves. The documents they transfer can be used to blackmail and/or increase the ransom. Businesses from every corner of the world has been hit by ransomware attacks and its only anticipated to become an even bigger threat now that these famous groups have made a lot of money on it. We will never know how much money have been paid in ransom since there are a lot of attacks not being reported but we have some numbers accessible for us. Over 97 million USD has been confirmed paid in ransom and that does not include the costs these businesses have had during and after attacks. Additional costs might be hiring security specialists, refunding costumers, brand damage, reputation damage and miscellaneous. A data breach in 2021 can cost as much as 4,24 million USD without payment of ransom (Cost of a Data Breach Report 2021, 2021). The 97 million USD mentioned above is not credited to just one group, it is spread over multiple:

- Netwalker/Mailto has had 27,3 million USD paid in ransom.
- Conti has had 16,2 million USD paid in ransom.
- Locky has had 14,06 million USD paid in ransom.
- REvil/Sodinokibi had 12,1 million USD paid in ransom.
- Darkside had 9,1 million USD paid in ransom.
- Ryuk had 4,6 million USD paid in ransom.
- RagnarLocker had 4,5 million USD paid in ransom.
- MountLocker had 4,2 million USD paid in ransom.
- BlackMatter had 4,6 million USD paid in ransom.
- Egregor had 3,1 million USD paid in ransom.

These sums are not only huge but should be looked at with a suspicious eye. They can be higher due to numbers not always being publicly available (Cable, n.d.). As shown above, the existence of ransomware is not to be taken lightly. There are many groups operating on the internet and some of them are known to license out their software. Spider Wizard is one of those groups. The ransomware software called Conti, Ryuk and Diavol are created by Spider Wizard which has been known for ransomwares over the whole world (Hanel, 2019) (Umawing, 2021).

Spider Wizard's Conti has been known for sophisticated attacks and Spider Wizard licenses out this ransomware for a share of the profits from the attacks. Conti is known as a Ransomware as a Service software that CISA, FBI and NSA have all warned against, with over 400 confirmed attacks of USA based organizations . Conti is known as a sophisticated ransomware because it looks for network drives and connected computers automatically. This allows the ransomware to spread unhinged over the network if it is not stopped before it is too late. This is one of the reasons ransomware is so dangerous, it encrypts everything it can find (CISA, FBI, and NSA Release Conti Ransomware Advisory to Help Organizations Reduce Risk of Attack | CISA, 2021).

It is worth mentioning that these groups often disappear for some time and show up with an even stronger attack. The group called REvil disappeared for some time after a couple of their attacks, but now multiple news sources are reporting that the Russian Government/FSB has launched a raid and criminal investigation against the members (Patteson, 2022).

Everything between small one person companies and Fortune 500 companies have been hit by ransomware, and it should be of a concern for your business too:

- USA's The Colonial Pipeline Company was hit by DarkSide in 2021 (Colonial Pipeline Cyber Incident, 2021) (Colonial Pipeline boss confirms $4.4m ransom payment, 2021).
- Kaseya was hit by REvil in 2021 (Kaseya CEO: "The impact of this incredibly sophisticated attack is very minimal", 2021) (Symantec, 2021).
- Acer was hit by REvil twice, in 2021 (Mathews, 2021).
- CNA Financial was hit by Phoenix in 2021 (Chang, 2021) (Mehrotra and Turton, 2021).
- ExaGrid was hit by Conti in 2021 (Nichols, 2021).
- AXA S.A was hit by Avaddon in 2021 (Insurance giant AXA victim of ransomware attack, 2021).
- Ireland's Health Service Executive was hit by Conti ransomware in May 2020 (PWC, 2021).
- Norwegian Media company Amedia's was hit with malware in December 2021. Unknown type of malware (Oppdatering om dataangrepet mot Amedia, 2022) (Sviggum, Berge Christensen and Heiberg Hellstrand, 2021).
- JBS Foods was hit by REvil in 2021 (Waldman, 2021).
- Quanta was hit by REvil in 2021 (Waldman, 2021) (Mehrotra, 2021).
- Norsk Hydro was hit by an unknown type of ransomware in 2019 (Cyber-attack on Hydro, n.d.).
- Estimated 230,000 computers was infected by WannaCry in 2017 (What was WannaCry?, n.d.).

The financial impact of a sophisticated attack is humongous. The attack can stop production and services your business delivers. It can force your company to go bankrupt if it does not have an incident response plan ready. Some of the companies that have been hit by ransomware has been critiqued for not having a good enough response plan, backups, and training of personnel (Buggeland, 2021). Computers and servers are being used by companies all over the world and they have software on them that might have a vulnerability. The vulnerability could be a zero-day vulnerability or could be known for a long time. A zero-day vulnerability is unknown to the software creators before that day, which gives them zero days to respond to it. These attacks are especially dangerous since it typically takes some time for a fix to be pushed out to the public. Some companies are very slow at updating their software which leaves them vulnerable. The FBI has even hacked into servers before to patch software vulnerabilities. FBI specifically

went in using a previous vulnerability on Microsoft exchange software which they patched and closed behind them (Hern, 2021). This proves how important it is to regularly check for updates, verify the updates and patch software on every server and system your company might run.

JSL

Costs of a malware attack

A malware attack can vary in costs but one thing is for certain, it is expensive. In 2020, being attacked by malware cost you on average 3.8 million USD while in 2021 the average cost rose to 4.2 million USD. Costs where remote work was involved was over 1 million USD more expensive to deal with. According to IBM's costs of a data breach report 2021 it was cheaper to have a well-maintained cybersecurity team than to not have one. "Costs were significantly lower for some of organizations with a more mature security posture, and higher for organizations that lagged in areas such as security AI and automation, zero trust and cloud security (Cost of a Data Breach Report 2021, 2021). " IBM also states that the biggest cost was lost business which averaged at 1.59 million USD in 2021 while in 2020 it averaged at 1.52 million USD. In 44% of breaches, personal information related from a customer was commonly lost. This cost average at 180 USD per lost record. If your company lost 14,500 records of customer personally identifiable information (PII) it would cost 2.6 million USD for the lost PII's alone.
The direct and indirect costs for your company are not a set sum, it could cost less or more. It is important to note that costs also differentiate with the attack types. A phishing attack averaged at 4.65 million USD. A malicious insider attack averaged at 4,61 million USD. If your company was targeted and attacked by manipulating (social engineering) your employees, the cost could average around 4.47 million USD. If your business email was compromised, an attack averaged at 5.01 million USD, which also is the most expensive one out of the attacks mentioned here. To put it in context, a breach consisting of 50 million records averaged 401 million USD (Cost of a Data Breach Report 2021, 2021).

Data breaches and malware attacks are expensive but the cost can be cut hiring a cyber security team. The security team will know how to counter some of these attacks or at least delay them so the system can automatically warn IT specialists of a possible ongoing attack. There are many ways to protect your systems, and we will mention some of them here.

- System hardening – Disables and adds different types of software to make a system more resistant to vulnerabilities
  Example: Enchaning Windows Defenders / Windows Security's ability to detect potentially malicious software.
- Zero Trust – Give users only access to what they need to interact with on a daily basis.
  Example: Don't give administative access to someone who do not need it.
- Antimalware / Antivirus software – Different types of software that helps protect your system from malware and viruses.
  Example: Malwarebytes, Kaspersky, BitDefender or Windows Security
- User and Entity Behaviour Analytics (UEBA) – Software that analyze your systems/users normal behaviour and can detect when abnormal behaviour is happening.
  Example: Teramind, Microsoft Defender for Identity, Activtrak, Varonis Data Security Platform
- Firewalls – Protects the network by checking ingoing/outgoing traffic and stopping potentially harmful attacks.
  Example: First generation firewall – Connection oriented. Second generation firewall – Content Oriented. Third generation firewall – Intent Oriented.
- Intrusion Detection and Prevention systems (IDPS) and Next-Generation Intrusion Prevention System (NGIPS) – Software/hardware that can detect and prevent malicious actors and files from being executed.

Example: NGIPS can detect potential malicious activity and track the spread of malware while it tries to spread over the network.

There are plenty more ways to protect a network and system, but this was a quick explanation to some of them.

By implementing Zero Trust, you could lower the costs of an attack by 1.7 million USD. With Zero Trust not deployed it could cost you 5 million USD while with Zero Trust deployed it lowered the costs to 3.2 million. If your company has a security focused AI or automation deployed on the network, it could lower your cost from 6.7 million USD to 2.9 million USD. That is a 3.8 million USD difference and does not include potential lost PII that could cause an even bigger damage if the information is confidential or potentially life threatening to your customers/employees. With a cloud system in place, your company can detect breaches over 77 days faster than the companies who don't have a mature cloud system. This shows how important it is with a well-developed and mature security system in place. The only issue a business might have with cyber security is that it is expensive to maintain. You need equipment, protocols, hardware, software, subscriptions to software, even more equipment, IT specialists and so on. A typical business measures costs and returns, but IT does not generate any sort of return except when it saves you money from being hit by a cyber-attack (Cost of a Data Breach Report 2021, 2021).

According to Kaspersky, if you have a 100 endpoints in your business spread over two offices it ranges between 33000 to 55000 USD annually. On premise security can cost you 55000 USD annually, cloud security can cost 34000 USD annually. If you want both security systems that can lower your cost of a data breach with over a million USD, it is going to cost you over 89000 each year. It is important that these costs are not for any specific business and it could be a lot more expensive, it depends on which security systems you have in place and what kind of budget IT gets. There is however a third option to these systems, outsourcing. With this option you have no one in house, only another company in another location. They take care of everything and can control it remotely. This is called having a Managed Service Provider (MSP). This can cost your 100 endpoint, two offices business 36000 USD annually. For smaller or medium sized businesses or organizations this is cheaper and provides protection. Having onsite support is something you miss out on with having an MSP but that might be worth it for smaller businesses. All the costs mentioned above are not set in stone. The final price you will have to use annually on cybersecurity depends on what solution you choose when it comes to firewalls, hardware, software or if you go for an MSP (Cybersecurity for business counting the costs finding the value, n.d.).

Government involvement

Multiple governments have been identified as the attacker in multiple malicious malware attacks. Norwegian Police Security Service (Politiets Sikkerhetstjeneste, PST) has identified multiple foreign governments in attacks and publicly gone out with this information. In August 2020 Norway's Storting (Stortinget) was hacked and Fancy Bear was identified by PST as the attacker (Matre, Johnsen and Camilo Lode, 2020). Fancy Bear has been linked to Russia's military group FSB (Federal Security Service // Federal'naya sluzhba bezopasnosti Rossiyskoy Federatsii) and GRU (Main Intelligence Directorate of the General Staff of the Armed Forces of the Russian Federation // Glavnoye Razvedyvatel'noye Upravleniye). Fancy Bear is allegedly the same group as APT28, APT29, STROTNUM and Unit 26165 (GRU, n.d.).

North-Korea also has their hand in different types of hacks. Ransomware software called WannaCry which reigned terror on Windows computers in 2017 has been linked to North-Korean military groups. APT38/Lazarous Group has been linked to North-Korea's intelligence agency called Reconnaissance General Bureau. This group has lately been focusing on cryptocurrency theft and in 2021 they stole over 400 million USD in cryptocurrency (North Korean Hackers Have Prolific Year as Their Unlaundered Cryptocurrency Holdings Reach All-time High - Chainalysis, 2022). China also has government backed groups. The group has been named APT27/Emissary Panda and Winnti. These groups have been known to attack for financial gain and attacks aimed at gaming organizations (Muncaster, 2021).

The United States of America has a group called NSA (National Security Agency) which focuses more on protecting USA but they are known to use and abuse different vulnerabilities in software to gain information. They have previously used a vulnerability called Eternalblue/CVE-2017-0144 and are known to have developed sophisticated hacking tools. WannaCry also used Eternalblue to spread (What was WannaCry?, n.d.). Other countries have been known to fund hacking groups but these are the most well-known ones.

Incident response plan

Having an incident response plan should be something every business that relies on computer systems and servers has fully developed and ready for potential everyday deployment. An incident response plan can help you and your business by getting your data systems up and running and potentially lower the cost of an attack. The plan should consist of what your IT employees are going to do when you hit by a cyberattack or finding out that malware has been roaming on your servers. In short, it consists of a "what do I do?" that you can check when you are responding to a cyberattack. That way you can immediately deploy countermeasures, reset systems, wipe data drives, deploy backups, and report the attack to your local authorities. Reporting incidents to local authorities is important. They can provide legal counsel, warn other businesses and the police can start a criminal investigation (NIST Special Publication 800-61 Revision 2, 2012).

Below I will go through what you should have in an incident response plan but it is not something you can grab from the internet. Each business needs a specific plan for their specific system, this is something we can help with. A U.S Department of Commerce institute called National Institute of Standards and Technology has certain recommendations we will follow in this report.
An incident response plan is also a Payment Card Industry Data Security Standard (PCIDSS) requirement (NIST Special Publication 800-61 Revision 2, 2012).

JSL

You have been hacked

Let us pretend your business has been hacked or a cyber incident has taken place. Below we will make an incident response plan that follows NIST's Computer Security Incident Handling Guide, NIST Special Publication 800-61 Revision 2 (NIST Special Publication 800-61 Revision 2, 2012).

According to the NIST, a good incident response plan needs a lifecycle. This cycle covers the different steps you will need to take.

1. Preparation
2. Detection & Analysis
3. Containment, Eradication & Recovery
4. Post Incident Activities.

Preparation

This step takes place before the attack and prepares your team to handle the incident. During an emergency your incident response team will need different contact information and ready-made information so they do not waste any time during the incident. According to NIST you will need:

- Contact information – For people in leadership positions, team members, law enforcement, other incident response teams, on-call information and different encryption keys used on data. Includes: Phone numbers, Email and ways of verifying identities.
- Mechanisms for reporting incidents – Users can report potential incidents to the IT team. Should include one or more: Phone number, Email or online form.
- System for tracking issues – To track incident information and status for both users and IT personnel.
- Phones – For communication between members both on and off site.
- Encryption software – Secure encrypted communication between members. File transfers etc.
- Temporary/Permanent incident response rooms – Used for communication and a hub for your IT team to work from. Complete with laptops, phones and different computer systems.
  If the room is not permanent, you will need plans on how to set up the room.
- Secure storage area – For securing evidence, logs, sensitive data and PII
- Laptops, workstations, servers, spare equipment, portable printers, packet sniffer software, protocol analyzers software, antimalware software forensic software, blank USB/Data drives, USB/Data drives with verified programs, backups, clean OS's and clean versions of software needed for users day to day use – For use during the incident to write reports, analyze malware, respond to the threats and eradicate malware.
- Ways to gather evidence – Notebooks, cameras, audio recorders, chain of custody forms, ways to store items and tag them.
- Documentation for software, OS and used in the business. Port lists, lists of critical assets, system diagrams. Cryptograh hashes for encrypted files.

Detection & Analysis
This stage covers how you should detect and analyze different attacks. You should have a plan for specific attacks and not a general plan like this one.
Typical attacks:

- Removable media: Attacks coming from pheripheral devices being connected to the system.
- Attrition: Uses brute force methods to degrade or compromise systems (DDoS attacks, username/password brute force attacks)
- Web: Attacks coming from a website/web application. (cross site scripting (XSS) attacks etc)
- Email: Executed using email or attachment (phishing)
- Impersonation: Where someone impersonates a person in a higher role to give out access. (Spoofing, man in the middle attacks, rouge AP's, SQL injection)
- Improper Usage: User install software that is not cleared by IT, illegal use of computer system etc.

There are multiple ways of countering these attacks. Some of these ways include antimalware, antivirus, firewalls, user policies, logs in different systems, IDPS, NGIPS, file integrity software, software/hardware hardening and/or other security protocols done manually by system administrators/network personnel. With these systems deployed we can detect and quickly respond to potential malicious attacks efficiently. This allows the IT security team to initiate the incident response plan and limit the destruction a cyber-attack can cause.

Analyzing malware and understanding how to eradicate it can be a time-consuming job. If the malware is already detected by other security firms, it might have a specific hash value and tips on how to eradicate it. This does not happen in every case, but your team might be lucky. In an incident its recommended to:

- Profile your networks and systems – What is the expected activity from hosts and servers? How much bandwith do they take up? How much data do they use? How much CPU, RAM and hard drive space does your system typically operate at?
- Normal behaviour – Reviewing logs for abnormalities, filtering logs for efficiency, revewing logs for abnormalities that might hide as a normal abnormalitiy.
- Log retention policy – Specifies how long log data should be kept. Logs can help your IT team see if the cyber attack triggered firewalls, file checking software or application errors cause by the attack.
- Synchronize Clocks – Make sure every piece of hardware runs on a standard time that is synchronized on the whole system. This helps the IT team when they read logs and see 17:00 from the firewall and 18:59 from the IDPS when they are actually on the same timezone. This can cause confusion and make an attack harder to eradicate and detect.
- Incident prioritization – Do you have multiple incidents happening at once? Which one is more severe and which one can you try to pause before initiating a incident plan?

You should also include some additional information when keeping statuses on systems. Does the attack impair functions on the network? If so, how much? Was information compromised? How big was the breach? Do you need additional resources?

Below is an outtake from NIST's different categories with definitions to easier differentiate between system function levels:

- Functional Impact Categories
  None - No effect to the organization's ability to provide all services to all users
  Low - Minimal effect; the organization can still provide all critical services to all users but has lost efficiency
  Medium - Organization has lost the ability to provide a critical service to a subset of system users
  High - Organization is no longer able to provide some critical services to any users
- Information Impact Categories
  None - No information was exfiltrated, changed, deleted, or otherwise compromised
  Privacy breach - Sensitive personally identifiable information (PII) of taxpayers, employees, beneficiaries, etc. was accessed or exfiltrated
  Properitary breach - Unclassified proprietary information, such as protected critical infrastructure information (PCII), was accessed or exfiltrated
  Integrity loss - Sensitive or proprietary information was changed or deleted
- Recoverability Effort Categories
  Regular - Time to recovery is predictable with existing resources
  Supplemented - Time to recovery is predictable with additional resources
  Extended - Time to recovery is unpredictable; additional resources and outside help are needed
  Not Recoverable - Recovery from the incident is not possible (e.g., sensitive data exfiltrated and posted publicly); launch investigation

JSL

Lastly, it is important to notify whoever needs to be notified. CEO, Infosec manager, system owner, etc.

Containment, Eradication & Recovery

Now we must contain the attack and this is also different with each type of attack (DDoS, types of malware). Containment of a system can include a full shutdown, running in offline mode, disabling different additional functions.
There isnt a general list that works for every type of attack but this one will go over different things you need to think about before choosing how you want to contain:

- Damage to or theft of resources
- Evidence preservation
- Service availability – services provided to costumers
- Effectiveness of strategies – full shutdown, half shutdown, full containment, system halt, etc
- Duration – How long is the containment going to last. 4 hours, untill further notice, for 5 days etc

For future references, evidence, criminal investigations, internal investigations it is always recommended to gather serial numbers, model numbers, hostnames, MAC addresses and IP addresses of affected systems and where the attack came from. Numbers, title, name of who handled evidence and logs. Time and date of the attack duration and where the evidence was stored.

In some cases, it can benefit your team to gather evidence on the attacker, if it is possible. The attackers will most likely try to obscure their real IP and MAC address but it is possible if the attacker has made mistakes.

- IP address – From the attacker. Important to validate it so you know if it is coming from a publicly available data center or a garage etc.
- Incident databases – CVE is a US homeland department and CISA incident reporting tool. Your team can find information here regarding a possible cyber attack or vulnerabilities that have been exploited. There are other incident databases you can also use.
- Possible hostile communications channels – Monitoring forums/IRC channels the attackers might use to brag is useful for potentially figuring out the exploit used. This way you might be able to contain and eradicate an attack quicker.

Eradication might involve deactivating certain abilities on your system, user accounts, emails and possibly change your whole infrastructure. These are short- and long-term solutions that in the end will help raise your security level and possibly let your system detect a future cyber-attack. This can lower costs, damage, and strengthen the corporations IT department/MSP

Post Incident Activities

At this stage you must go over the attack and try to find points of improvement

- Why did it happen – What was the cause. User? Email vulnerability? System failure? IDPS configured wrong? New firewall? Better firewall? Etc.
- When did it happen.
- How can we improve our own systems resistance to these attacks – Update firewall rules, tweak security software, teach users how to stay safe etc.
- How can we improve our incident response plan – Was anything wrong or can something be improved upon to quicker respond to the incident.
- What was positive and negative about the attack – Did IT respond like they should? Can we improve our systems security?

It is important to not think that your system is always protected against everything. Software and hardware will have vulnerabilities we don't know about, your MSP could have a vulnerable administrator account or one of your users could have a breached account. It is dangerous to leave a computer system alone and without supervision. As mentioned above, this could cost your business many millions of U.S dollars in damage quickly.

Conclusion

In this report we have gone over what malware is, malware as a service, ransomware as a service, what ransomware is, criminal use of malware, how much it could cost your business, government involvement, why you need an incident response plan and how you make an incident response plan.

The usage of computer systems in businesses is rising quickly and is mainly the standard in 2022. Everyone uses it and everyone expect everyone to use it. Because of this we are leaving us vulnerable to cyber-attacks without the proper knowledge on how to plan for it, detect & analyze, contain & eradicate, and get your system up and running again. This is impossible to do without hiring IT personnel or an MSP that can provide all this knowledge to you and your company.

In 2021, the average cost of a data breach was 4.2 million USD. The lost revenue could be lost PII's, business, confidential data, and similar items you could potentially loose in a cyber-attack. If you got successfully attacked by ransomware, it could cost your business many thousands of dollars or potentially double digits million USD. By having a confident and knowledgeable IT department you could lower the cost of a cyber-attack. According to IBM, "Costs were significantly lower for some of organizations with a more mature security posture, and higher for organizations that lagged in areas such as security AI and automation, zero trust and cloud security." (Cost of a Data Breach Report 2021, 2021). Just by implementing zero-trust, you can potentially save 1.7 million USD. If you choose to have an internal IT department or an MSP, they will do this for you. It will cost money annually and be a cost for your business, but nowhere near what a cyber-attack would cost and the damage done by the cyber-attacks (Cybersecurity for business counting the costs finding the value, n.d.).

Therefore, you should hire us.

JSL

References

Amedia.no. 2022. *Oppdatering om dataangrepet mot Amedia*. [online] Available at: <https://amedia.no/aktuelt/nyheter/item/4-januar-oppdatering-om-dataangrepet-mot-amedia> [Accessed 7 January 2022].

Ashford, W., 2019. *Norsk Hydro cyber attack could cost up to $75m*. [online] computerweekly.com. Available at: <https://www.computerweekly.com/news/252467199/Norsk-Hydro-cyber-attack-could-cost-up-to-75m> [Accessed 15 January 2022].

bbc.com. 2021. *Colonial Pipeline boss confirms $4.4m ransom payment*. [online] Available at: <https://www.bbc.com/news/business-57178503> [Accessed 15 January 2022].

Bird, J., 2018. *Cyber attacks bought 'as easily as online shopping'*. [online] Ft.com. Available at: <https://www.ft.com/content/b5273822-548a-11e8-84f4-43d65af59d43> [Accessed 7 January 2022].

Bischoff, P., 2021. *The cost of hiring a hacker on the dark web*. [online] Comparitech. Available at: <https://www.comparitech.com/blog/information-security/hiring-hacker-dark-web-report/> [Accessed 7 January 2022].

Buggeland, S., 2021. *IT-ekspert om Amedia-angrep: – Ikke gode nok rutiner*. [online] Vg.no. Available at: <https://www.vg.no/nyheter/i/WjeVbL/it-ekspert-om-amedia-angrep-ikke-gode-nok-rutiner> [Accessed 7 January 2022].

Business Insurance. 2017. *More than 40% companies blame competitors for cyber attacks: Research - Business Insurance*. [online] Available at: <https://www.businessinsurance.com/article/20170307/STORY/912312267/More-than-40-companies-blame-competitors-for-cyber-attacks-Research> [Accessed 7 January 2022].

Cable, J., n.d. *Ransomwhere*. [online] Ransomwhe.re. Available at: <https://ransomwhe.re/> [Accessed 7 January 2022].

Chang, B., 2021. *One of the biggest US insurance companies reportedly paid hackers $40 million ransom after a cyberattack*. [online] Business Insider. Available at: <https://www.businessinsider.com/cna-financial-hackers-40-million-ransom-cyberattack-2021-5?r=US&IR=T> [Accessed 7 January 2022].

Christos, K., 2020. *Big Business Hired Hackers to Destroy Competition: Is Your SMB At Risk?*. [online] Linkedin.com. Available at: <https://www.linkedin.com/pulse/big-business-hired-hackers-destroy-competition-your-smb-kim-christos> [Accessed 7 January 2022].

cisa.gov. 2021. *CISA, FBI, and NSA Release Conti Ransomware Advisory to Help Organizations Reduce Risk of Attack | CISA. [online] Available at: <https://www.cisa.gov/news/2021/09/22/cisa-fbi-and-nsa-release-conti-ransomware-advisory-help-organizations-reduce-risk>* [Accessed 18 January 2022].

Encyclopedia.kaspersky.com. n.d. *Malware-as-a-service (MaaS)*. [online] Available at: <https://encyclopedia.kaspersky.com/glossary/malware-as-a-service-maas/> [Accessed 15 January 2022].

Energy.gov. 2021. *Colonial Pipeline Cyber Incident*. [online] Available at: <https://www.energy.gov/ceser/colonial-pipeline-cyber-incident> [Accessed 7 January 2022].

Evans, S., 2017. *Businesses Blame DDoS Attacks on Rival Companies*. [online] Infosecurity-magazine. Available at: <https://www.infosecurity-magazine.com/news/businesses-blame-ddos-attacks/> [Accessed 7 January 2022].

Foret, W., 2019. *Council Post: Using Cyber Security As A Competitive Advantage*. [online] Forbes. Available at: <https://www.forbes.com/sites/forbesbusinesscouncil/2019/10/09/using-cyber-security-as-a-competitive-advantage/?sh=417f044d7ff7> [Accessed 7 January 2022].

Gallagher, C., 2021. *Dark web 'dump sites' being monitored for HSE data after hack*. [online] irishtimes.com. Available at: <https://www.irishtimes.com/news/crime-and-law/dark-web-dump-sites-being-monitored-for-hse-data-after-hack-1.4567731> [Accessed 7 January 2022].

Greig, J., 2020. *Research shows malware is easy to buy, own, and deploy*. [online] techrepublic.com. Available at: <https://www.techrepublic.com/article/research-shows-malware-is-easy-to-buy-own-and-deploy/> [Accessed 7 January 2022].

group-ib.com. 2020. *Group-IB reveals its cyberthreat forecast for the coming year*. [online] Available at: <https://www.group-ib.com/media/gib-report-2020/> [Accessed 7 January 2022].

Halpin, P. and Humphries, C., 2021. *Irish health service hit by 'very sophisticated' ransomware attack*. [online] Reuters.com. Available at: <https://www.reuters.com/technology/irish-health-service-hit-by-ransomware-attack-vaccine-rollout-unaffected-2021-05-14/> [Accessed 7 January 2022].

Hanel, A., 2019. *What is Ryuk Ransomware? The Complete Breakdown*. [online] crowdstrike.com. Available at: <https://www.crowdstrike.com/blog/big-game-hunting-with-ryuk-another-lucrative-targeted-ransomware/> [Accessed 7 January 2022].

Hern, A., 2021. *FBI hacks vulnerable US computers to fix malicious malware*. [online] theguardian.com. Available at: <https://www.theguardian.com/technology/2021/apr/14/fbi-hacks-vulnerable-united-states-computers-to-fix-hack-malicious-malware-microsoft-exchange-software> [Accessed 15 January 2022].

Horgan-Jones, J. and Lally, C., 2021. *Cyberattack on HSE: Scale of damage on systems will not be known for days*. [online] irishtimes.com. Available at: <https://www.irishtimes.com/news/health/cyberattack-on-hse-scale-of-damage-on-systems-will-not-be-known-for-days-1.4565621> [Accessed 7 January 2022].

Hydro.com. n.d. *Cyber-attack on Hydro*. [online] Available at: <https://www.hydro.com/en/media/on-the-agenda/cyber-attack/> [Accessed 7 January 2022].

Ibm.com. 2021. *Cost of a Data Breach Report 2021*. [online] Available at: <https://www.ibm.com/security/data-breach> [Accessed 7 January 2022].

Karafiloski, D., 2021. *Cost of cyber attacks vs. Cost of cybersecurity in 2021 | Sumo Logic*. [online] Sumo Logic. Available at: <https://www.sumologic.com/blog/cost-of-cyber-attacks-vs-cost-of-cyber-security-in-2021/> [Accessed 7 January 2022].

kaspersky.com. n.d. *Cybersecurity for business counting the costs finding the value*. [online] Available at: <https://media.kaspersky.com/en/business-security/cybersecurity-for-business-counting-the-costs-finding-the-value.pdf> [Accessed 16 January 2022].

kaspersky.com. n.d. *The biggest ransomware threats of 2017*. [online] Available at: <https://usa.kaspersky.com/resource-center/threats/biggest-ransomware-threats-2017> [Accessed 15 January 2022].

kaspersky. n.d. *What is a Botnet?*. [online] Available at: <https://usa.kaspersky.com/resource-center/threats/botnet-attacks> [Accessed 7 January 2022].

Malwarebytes Labs. 2021. *Kaseya CEO: "The impact of this incredibly sophisticated attack is very minimal"*. [online] Available at: <https://blog.malwarebytes.com/ransomware/2021/07/kaseya-ceo-the-impact-of-this-incredibly-sophisticated-attack-is-very-minimal/> [Accessed 7 January 2022].

Malwarebytes.com. n.d. *What was WannaCry?*. [online] Available at: <https://www.malwarebytes.com/wannacry> [Accessed 15 January 2022].

Mathews, L., 2021. *Acer Faced With Ransom Up To $100 Million After Hackers Breach Network*. [online] Forbes. Available at: <https://www.forbes.com/sites/leemathews/2021/03/21/acer-faced-with-ransom-up-to-100-million-after-hackers-breach-network/> [Accessed 7 January 2022].

Matre, J., Johnsen, N. and Camilo Lode, S., 2020. *PST mener russiske militær-hackere sto bak angrepet mot Stortinget*. [online] Vg.no. Available at: <https://www.vg.no/nyheter/innenriks/i/7KPmyB/pst-mener-russiske-militaer-hackere-sto-bak-angrepet-mot-stortinget> [Accessed 7 January 2022].

Meharchandani, D., 2020. *Cybercrime Expected to Rise At an Unprecedented Rate in 2021*. [online] Security Boulevard. Available at: <https://securityboulevard.com/2020/12/cybercrime-expected-to-rise-at-an-unprecedented-rate-in-2021/> [Accessed 7 January 2022].

Mehrotra, K. and Turton, W., 2021. *CNA Financial Paid $40 Million in Ransom After March Cyberattack*. [online] Bloomberg.com. Available at: <https://www.bloomberg.com/news/articles/2021-05-20/cna-financial-paid-40-million-in-ransom-after-march-cyberattack> [Accessed 7 January 2022].

Mehrotra, K., 2021. *Apple Targeted in $50 Million Ransomware Hack of Supplier Quanta*. [online] Bloomberg.com. Available at: <https://www.bloomberg.com/news/articles/2021-04-21/apple-targeted-in-50-million-ransomware-hack-of-supplier-quanta> [Accessed 7 January 2022].

Merritt, T., 2021. *Top 5 ransomware operators by income*. [online] TechRepublic. Available at: <https://www.techrepublic.com/article/top-5-ransomware-operators-by-income/> [Accessed 7 January 2022].

Mikalauskas, E., 2020. *Report: buying your own malware has never been easier*. [online] cybernews.com. Available at: <https://cybernews.com/security/buying-your-own-malware-has-never-been-easier/> [Accessed 7 January 2022].

Muncaster, P., 2021. *Chinese APT Group Linked to Ransomware Attacks*. [online] infosecurity-magazine.com. Available at: <https://www.infosecurity-magazine.com/news/chinese-apt-group-linked-to> [Accessed 15 January 2022].

n.d. Module 2 - *Vulnerabilities, Malware & Cryptography -> Lesson 2.4 Crypto-Malware*.

Nichols, S., 2021. *ExaGrid revealed as latest Conti ransomware casualty*. [online] SearchSecurity. Available at: <https://www.techtarget.com/searchsecurity/news/252501823/ExaGrid-revealed-as-latest-Conti-ransomware-casualty> [Accessed 15 January 2022].

nist.com. 2021. *Ransomware*. [online] Available at: <https://www.nist.gov/itl/smallbusinesscyber/guidance-topic/ransomware> [Accessed 7 January 2022].

nist.gov. 2012. *NIST Special Publication 800-61 Revision 2*. [online] Available at: <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-61r2.pdf> [Accessed 16 January 2022].

Nomios Group. n.d. *What is REvil ransomware?*. [online] Available at: <https://www.nomios.com/resources/what-is-revil-ransomware/> [Accessed 7 January 2022].

paloaltonetworks.com. 2021. *Highlights from the 2021 Unit 42 Ransomware Threat Report*. [online] Available at: <https://unit42.paloaltonetworks.com/ransomware-threat-report-highlights/> [Accessed 7 January 2022].

Patteson, C., 2022. *Russia shuts down REvil ransomware group as Ukraine tensions grow*. [online] nypost.com. Available at: <https://nypost.com/2022/01/14/russia-shuts-down-revil-ransomware-group-as-ukraine-tensions-grow/> [Accessed 15 January 2022].

PWC, P., 2021. *Conti cyber attack on the HSE*. [online] Hse.ie. Available at: <https://www.hse.ie/eng/services/publications/conti-cyber-attack-on-the-hse-full-report.pdf> [Accessed 7 January 2022].

Rapid7. 2021. *Security Nation: Jack Cable on Ransomwhere | Rapid7 Blog*. [online] Available at: <https://www.rapid7.com/blog/post/2021/10/27/security-nation-jack-cable-on-ransomwhere/> [Accessed 7 January 2022].

Rieß-Marchive, V. and Adshead, A., 2021. *Exagrid pays $2.6m to Conti ransomware attackers*. [online] computerweekly.com. Available at: <https://www.computerweekly.com/news/252501665/Exagrid-pays-26m-to-Conti-ransomware-attackers> [Accessed 15 January 2022].

Securitymagazine.com. 2021. *Insurance giant AXA victim of ransomware attack*. [online] Available at: <https://www.securitymagazine.com/articles/95245-insurance-giant-axa-victim-of-ransomware-attack> [Accessed 7 January 2022].

Sjouwerman, S., 2021. *Council Post: Ransomware Gangs: Who Are They And How To Stop Them*. [online] Forbes. Available at: <https://www.forbes.com/sites/forbestechcouncil/2021/09/27/ransomware-gangs-who-are-they-and-how-to-stop-them/> [Accessed 7 January 2022].

sophos.com. 2021. *The State of Ransomware 2021*. [online] Available at: <https://www.sophos.com/en-us/medialibrary/pdfs/whitepaper/sophos-state-of-ransomware-2021-wp.pdf?cmp=120469> [Accessed 7 January 2022].

Souppaya, M. and Scarfone, K., 2013. *Guide to Malware Incident Prevention and Handling for Desktops and Laptops*. [online] nist.gov. Available at: <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-83r1.pdf> [Accessed 7 January 2022].

ISL

Stouffer, C., 2021. *10 types of malware + how to prevent malware from the start | Norton*. [online] norton.com. Available at: <https://us.norton.com/internetsecurity-malware-types-of-malware.html> [Accessed 7 January 2022].

Sviggum, S., Berge Christensen, S. and Heiberg Hellstrand, S., 2021. *Hackernes beskjed til Amedia: «Viktige dokumenter er klare til å avsløres»*. [online] Vg.no. Available at: <https://www.vg.no/nyheter/innenriks/i/34X8jd/hackernes-beskjed-til-amedia-viktige-dokumenter-er-klare-til-aa-avsloeres> [Accessed 7 January 2022].

Swinhoe, D., 2020. *How much does it cost to launch a cyberattack?*. [online] CSO Online. Available at: <https://www.csoonline.com/article/3340049/how-much-does-it-cost-to-launch-a-cyberattack.html> [Accessed 7 January 2022].

Symantec, T., 2021. *Kaseya Ransomware Supply Chain Attack: What You Need To Know*. [online] Symantec-enterprise-blogs.security.com. Available at: <https://symantec-enterprise-blogs.security.com/blogs/threat-intelligence/kaseya-ransomware-supply-chain> [Accessed 7 January 2022].

chainalysis.com. 2022. *North Korean Hackers Have Prolific Year as Their Unlaundered Cryptocurrency Holdings Reach All-time High - Chainalysis*. [online] Available at: <https://blog.chainalysis.com/reports/north-korean-hackers-have-prolific-year-as-their-total-unlaundered-cryptocurrency-holdings-reach-all-time-high/> [Accessed 15 January 2022].

trendmicro.com. n.d. *Ransomware*. [online] Available at: <https://www.trendmicro.com/vinfo/us/security/definition/ransomware> [Accessed 15 January 2022].

trendmicro.com. n.d. *Ransomware as a Service (RaaS)*. [online] Available at: <https://www.trendmicro.com/vinfo/us/security/definition/ransomware-as-a-service-raas> [Accessed 7 January 2022].

Umawing, J., 2021. *Threat spotlight: Conti, the ransomware used in the HSE healthcare attack*. [online] Malwarebytes Labs. Available at: <https://blog.malwarebytes.com/threat-spotlight/2021/05/threat-spotlight-conti-the-ransomware-used-in-the-hse-healthcare-attack/> [Accessed 7 January 2022].

Waldman, A., 2021. *10 of the biggest ransomware attacks of 2021 -- so far*. [online] techtarget. Available at: <https://www.techtarget.com/searchsecurity/feature/The-biggest-ransomware-attacks-this-year> [Accessed 15 January 2022].

wikipedia.org. n.d. *GRU*. [online] Available at: <https://en.wikipedia.org/wiki/GRU> [Accessed 18 January 2022].

Wilkie, C., 2021. *Colonial Pipeline paid $5 million ransom one day after cyberattack, CEO tells Senate*. [online] cnbc.com. Available at: <https://www.cnbc.com/2021/06/08/colonial-pipeline-ceo-testifies-on-first-hours-of-ransomware-attack.html> [Accessed 7 January 2022].

www.kaspersky.co.uk. 2017. *Businesses Blame Rivals for Staging DDoS Attacks*. [online] Available at: <https://www.kaspersky.co.uk/about/press-releases/2017_businesses-blame-rivals-for-staging-ddos-attacks> [Accessed 7 January 2022].

www.kaspersky.com. 2018. *Sofacy shifts focus to include Far East defense and diplomacy, overlaps with advanced cyberespionage groups*. [online] Available at: <https://www.kaspersky.com/about/press-releases/2018_sofacy> [Accessed 7 January 2022].

JSL

Additional references

Below are links to different forums/marketplaces which carry data breach leaks, malware and different types of hacking software:

Potentially dangerous links

Zero Day Forum/Marketplace (English) - https://0day.zone/
VirusTotal:
https://www.virustotal.com/gui/url/6fe86ab30818bf72072aa860485f5e7d3e5c2b09d87365de9d2e3e935bb7e8a9

0x00sec Forum/Marketplace (English) - https://0x00sec.org/
VirusTotal:
https://www.virustotal.com/gui/url/353068b34f7e64a8e695318ded8859c9821532a7c4d3bf0c7372bc0f8a1b7bc0

24RC Forum/Marketplace (Russian) - https://24rc.biz/
VirusTotal -
https://www.virustotal.com/gui/url/6a0fc08e453b4e504fdfb7ef38e93fd0f4609eb4458275a197cd410c97660e16

FlameHack Forum/Marketplace (Russian) - https://flame-hack.com/
VirusTotal:
https://www.virustotal.com/gui/url/7aaa53e321944820c006a1423b249d32292f9cfa4c3e568550c50efde1ba77f2/summary

CYBHACK Forum/Marketplace (Russian) https://cybhack.net/
VirusTotal:
https://www.virustotal.com/gui/url/72a492422cd4ea940923fc3dc168c07f5f4e33174a1f22232641f99acb732659

Iran Cyber Forum/Marketplace (Iranian) - https://iran-cyber.net/forums/
VirusTotal:
https://www.virustotal.com/gui/url/0c5c736173b348cd2111f449e01c9a4659c2354c513982acbebfd12386ae4103

ToolBase Forum/Marketplace (German) - https://www.toolba.se/board/
VirusTotal:
https://www.virustotal.com/gui/url/e139adcd08fbe1bbbd26139cd8ed65fcd04a0810669f360daaf326ab4cd1b2ad

Onion sites:

TAPE Forum/Marketplace (English) -
http://tapefaqb6kz5buk4bqhnjv3oo3oi7xn6y6kpkjfh5hqu3t7e3dzr65yd.onion/

CryptBB Forum/Marketplace (English) -
http://cryptbbtg65gibadeeo2awe3j7s6evg7eklserehqr4w4e2bis5tebid.onion/

JSL

Cosmos Forum/Marketplace (English) -
http://qsr456rkpkialoyc4lo6kbr3nucbdlz5bfvpv4hvs2yj7fkanyv4yjqd.onion/

Kickass Private Forum/Marketplace (English) -
http://o3nqszgvtqwcc2mxqcqgeyulkh6spiv6yaahgu7znaphzmikfvpu5aad.onion/

Recon Forum/Marketplace (English) -
http://recon222tttn4ob7ujdhbn3s4gjre7netvzybuvbq2bcqwltkiqinhad.onion/

JSL